

Customer-managed keys (CMK)

Built by: Power CAT

This module walks you through encrypting a Power Platform environment with a customer-managed key (CMK) — an encryption key that you create and control in your own Azure Key Vault instead of the default key that Microsoft manages.

Labs in this module

Lab	Description
Prepare your Azure Key Vault	Confirm vault requirements and create the encryption key
Create the enterprise policy	Deploy an ARM template that links Power Platform to your key
Grant the enterprise policy access	Give the policy least-privilege access to your key vault
Apply the policy to your environment	Encrypt the environment with your key and monitor progress

Prerequisites

1. You have an Azure subscription with rights to create and manage Azure Key Vault and to deploy resources (for example, **Owner** or **Contributor** on the target resource group).
2. The **Microsoft.PowerPlatform** resource provider is registered in that subscription. Resource providers are the Azure services that supply resource types — this one supplies the `enterprisePolicies` type you deploy in the second lab, and the template deployment fails if it isn't registered. To check or register it, go to the Azure portal > **Subscriptions** > your subscription > **Resource providers**, search for `Microsoft.PowerPlatform`, and select **Register**. To learn more, see [Azure resource providers and types](#).
3. You have the **Power Platform administrator** role (or Global administrator) and access to the [Power Platform admin center](#).
4. You have a Power Platform environment of type **Sandbox**, located in the same Azure region as your key vault.
5. The environment is activated as a **Managed Environment** — the customer-managed key policy is only enforced on Managed Environments.
6. You have access to Azure Cloud Shell (PowerShell) for the role assignment step.

In addition, users in environments where the encryption key policy is enforced must have a qualifying subscription, such as Microsoft 365 or Office 365 A5/E5/G5 or one of the related F5 compliance offerings. See [Manage your customer-managed encryption key](#) for the current list and licensing details.

The enterprise policy experience is currently in **preview**. At the time of writing, it supports only Sandbox-type environments, and a policy can be applied only to environments in the same Azure region as the policy. Create a separate policy for each region.

While an environment is being encrypted with a customer-managed key, it is **taken offline**. Depending on the amount of data, this can take up to two days to complete. In a production tenant, schedule this activity during a planned maintenance window. In your lab tenant, use a Sandbox environment without business-critical users.

Business use case

Woodgrove Bank, a retail bank, runs its sales pipeline and customer engagement apps on Power Platform. Like all of the bank's data, this environment data is encrypted at rest — by default with a key that Microsoft manages on the bank's behalf.

During a security review, the bank's regulators and internal risk team raise a requirement that applies to every system holding customer data: Woodgrove Bank must own the full lifecycle of its encryption keys. Concretely, the bank must be able to:

- **Prove key ownership.** Demonstrate to auditors that the encryption key protecting customer data is created, held, and controlled by the bank in its own Azure Key Vault.
- **Control key rotation.** Rotate the key on the bank's schedule, in line with its internal cryptographic standards — not a vendor's.
- **Revoke access on demand.** In the event of a security incident or contract exit, disable the key and immediately render the environment data unreadable — a capability the risk team calls the “kill switch.”

The default Microsoft-managed key meets the bank's encryption requirement, but not its key ownership requirement. Customer-managed keys close that gap: the environment data stays in Power Platform, but the key that protects it lives in the bank's own vault, under the bank's own governance.

In this module, you play the role of a Woodgrove Bank administrator implementing CMK for the sales environment. The lab uses the following example names throughout — replace them with your own values as you go:

Resource	Example name
Resource group	CMKResourceGroupUS
Key vault	CMKAKVSales
Encryption key	cmksaleskey
Enterprise policy	CMKWUSSalesEP1
Environment	Sales Trial

How it works

A CMK configuration links three things: your Azure Key Vault key, a Power Platform **enterprise policy**, and your environment. The enterprise policy is essentially a pointer to a key in your vault. You grant the

policy access to the vault, then attach the policy to your environment. From that point on, Power Platform uses your key to encrypt the environment data.

What you learn

By the end of this module, you can:

- Configure an Azure Key Vault with the soft-delete and purge protection settings CMK requires.
- Create an RSA encryption key for Power Platform.
- Deploy a Power Platform enterprise policy with an ARM template.
- Grant the policy least-privilege access to the key vault and assign the Reader role.
- Apply the policy to an environment and monitor encryption status in the admin center.

Ready to get started? Go through the labs table above in order because each lab builds on the previous one.